

BEFORE Placeholder

AFTER

Contracting Overview by Tier (Critical / Important / Low)

Document classification: Internal

Document owner: Procurement (with Security and Legal/Privacy)

Version: 0.1

Effective date: _____

Review cadence: Annually

1. Purpose

This document summarises the minimum contractual security and privacy positions expected for suppliers by tier. It provides a repeatable baseline for Procurement and Legal Counsel to apply proportionate contract terms aligned to the Third-Party Security Program.

2. Principles

- Contract terms must reflect **tier and exposure** (data, access, connectivity, criticality, sub-processors).
- For Critical suppliers, minimum positions are treated as **non-negotiable unless formally excepted** via the program exception process.
- Privacy terms are owned by the **DPO/Privacy Officer** where personal data processing applies.
- Where a supplier cannot meet minimum positions, the decision to proceed requires **documented residual risk acceptance** per governance.

3. Tier definitions (summary)

- **Critical:** business critical and/or privileged access/production influence and/or sensitive data exposure and/or persistent connectivity/fourth-party risk.

- **Important:** meaningful integration and/or limited sensitive data without Critical triggers.
- **Low:** minimal exposure and low business impact.

4. Contractual baseline by tier

4.1 Critical (Tier 1) — minimum positions

Critical supplier contracts MUST include, at minimum:

A) Incident notification & cooperation

- Time-bound notification commitment for material incidents impacting service scope
- Cooperation obligations (timely information sharing, logs/evidence support, investigation updates)
- Post-incident reporting commitment (RCA + corrective actions and dates)

B) Security controls (service-appropriate)

- Commitment to maintain baseline security controls aligned to the tier requirements (referenced in security schedule)
- Control change notification for material security posture changes that affect service scope

C) Auditability & assurance

- Right to request assurance evidence (e.g., SOC/ISO, pen test exec summary) on a defined cadence
- Right to request additional evidence during material incidents
- Audit/evidence rights proportionate to risk and practicality

D) Sub-processors / outsourcing

- Sub-processor transparency (list available) and change notification commitments
- Flow-down of security/privacy obligations to sub-processors
- Restrictions or approval requirements for material outsourcing changes affecting service

E) Data protection & privacy (where applicable)

- DPA in place for personal data processing
- Data residency/processing locations disclosed and change-controlled
- Data retention limits and deletion/return obligations on termination
- Breach notification alignment with privacy obligations (DPO-led)

F) Resilience & recovery (where applicable)

- Availability/restoration expectations proportionate to criticality
- Backup/restore and recovery testing commitments (summary evidence acceptable)
- Communication expectations during outages

G) Offboarding

- Access removal support
- Data return and secure deletion confirmation on termination
- Support for transition/exit assistance where operationally necessary

Non-negotiable flags (default) for Critical suppliers:

- refusal to commit to incident notification and cooperation
- refusal to provide sub-processor transparency for material components
- inability to support baseline identity controls for admin access (e.g., MFA)
- inability to support adequate auditability/logging for in-scope activity without viable mitigations

4.2 Important (Tier 2) — minimum positions

Important supplier contracts MUST include:

- Incident notification commitment and security contact
- Appropriate cooperation during investigations (reasonable effort)
- Sub-processor transparency appropriate to scope
- Data return/deletion obligations where data is stored/processed
- Baseline security controls statement proportionate to the service

Important supplier contracts SHOULD include:

- Assurance evidence provision (SOC/ISO/pen test summary) where relevant
- Change notification for material security posture changes
- Privacy terms (DPA) where personal data processing applies (DPO-led)

4.3 Low (Tier 3) — minimum positions

Low supplier contracts SHOULD include (proportionate):

- Security contact and reasonable incident notification
- Confidentiality/data handling basics (if any data involved)
- Data deletion/return on termination where data is stored

Low supplier contracts MAY rely on standard procurement terms where:

- no organisational data is processed, and
- no integration/access is required, and
- business impact is low.

5. Negotiation guidance (high level)

- Apply tier baseline positions early (during onboarding) to avoid late-stage renewal surprises.
- If a supplier resists Critical-tier positions:
 - identify whether scope can be reduced (no privileged access, no sensitive data, no connectivity),
 - apply compensating controls where meaningful,
 - otherwise escalate for decision (proceed vs alternative supplier).

6. Link to program governance and exceptions

- Contract deviations from Tier baseline positions must be recorded as gaps and, where they affect MUST requirements, managed via the exception process:

- ``program-charter/04-policy-exceptions-standard.md``
- Escalation and residual risk acceptance per:
 - ``program-charter/02-governance-approvals-escalation.md``

7. Ownership and maintenance

- Procurement: owns standard supplier contracting workflow and ensures baseline positions are included.
- Legal Counsel: owns legal drafting and negotiation (non-privacy).
- DPO/Privacy Officer: owns privacy/DPA positions.
- Security Engineering/Architecture: defines security baseline positions and validates alignment to program requirements.